NAVY POČÍTAČOVÁ BEZPEČNOST

Cv3. Cross site scripting

Cvičení č. 3: Útok na ostatní uživatele – Cross-Site Scripting (XSS)

Cíl cvičení: Pochopit princip zranitelnosti Cross-Site Scripting (XSS) a dokázat spustit vlastní JavaScriptový kód přímo na stránce e-shopu. Získáte tak představu o tom, jak útočníci kradou cizí uživatelské relace (cookies) nebo přesměrovávají uživatele na podvodné weby.

Teoretický úvod: Co je XSS a proč je nebezpečné?

U minulé zranitelnosti (SQL Injection) jsme útočili na **databázi (backend)**. U XSS naopak útočíme na **prohlížeč ostatních uživatelů (frontend)**.

K XSS dochází ve chvíli, kdy webová aplikace vezme nějaký text od uživatele (například hledaný výraz, komentář nebo jméno) a bez kontroly ho zobrazí zpět na stránce. Pokud útočník místo běžného textu vloží HTML značky nebo JavaScriptový kód, prohlížeč oběti tento kód nerozpozná jako text, ale **spustí ho**.

Představte si, že do fóra napíšete místo pozdravu toto:

`<script>alert('Byl jsi hacknut!')</script>`

Každému uživateli, který si vaše vlákno otevře, by vyskočilo varovné okno. V reálném světě by tam ale nebyl neškodný `alert`, nýbrž tichý skript, který ukradne přihlašovací údaje.

Krok 1: Hledání zranitelného místa

Abychom mohli XSS provést, musíme najít místo, kde aplikace vypisuje náš vlastní text zpět na obrazovku.

1. Běžte na hlavní stránku Juice Shopu.
2. V horní liště klikněte na ikonu lupy (Vyhledávání).
3. Napište slovo `jablko` a stiskněte Enter.
4. Všimněte si textu, který se objeví nad výsledky (např. *"Search Results - jablko"*). Tohle je náš cíl!

Krok 2: Testování HTML injekce

Ověříme si, zda aplikace text pouze vypisuje, nebo jestli ho i interpretuje jako kód.

1. Do vyhledávání zadejte jednoduchou HTML značku pro nadpis, například: `<h1>Test</h1>`
2. Změnil se vzhled vypsaného textu? Je slovo "Test" obrovským písmem? Pokud ano, aplikace je zranitelná a můžeme přejít k injekci JavaScriptu.

Krok 3: Obejití ochrany (Samotný útok)

Vaším úkolem je donutit prohlížeč, aby zobrazil vyskakovací okno (tzv. alert) s textem `xss`.

Moderní aplikace jako Juice Shop ale nejsou úplně hloupé. Používají framework Angular, který základní XSS útoky blokuje. Pokud zadáte klasické `<script>alert('xss')</script>`, nic se nestane – Angular kód zablokuje. Musíte na to jít chytřeji!

Postupné nápovědy (použijte je, až když se zaseknete):

- 💡 **Nápověda 1:** Když nemůžete použít tag `<script>`, jaké jiné HTML prvky umí spouštět JavaScript? Co třeba obrázek, který se nenačte, nebo vložený rámec (iframe)?
- 💡 **Nápověda 2:** Zkuste využít tag `<iframe>`. Ten umožňuje vložit do stránky jinou webovou stránku. Do parametru `src` (zdroj) ale nedávejte URL adresu, nýbrž protokol `javascript:`.
- 💡 **Nápověda 3 (Konečný payload):** Zkuste do vyhledávacího pole vložit přesně tento kód: `<iframe src="javascript:alert('xss')">`

Úspěšné dokončení 🟢

Pokud jste útok provedli správně, okamžitě na vás vyskočí systémové okno prohlížeče se zprávou "xss". Jakmile ho odkliknete, aplikace vám opět pogratuluje ke splnění úkolu "DOM XSS" a na vašem Scoreboardu se objeví další zelená odškrtnutá položka.